

A Comparative Study of Data Protection Laws in Saudi Arabia and the United States

Jubran Alsughayyir

University of Washington School of Law

May 2024

Research Paper

INTRODUCTION

The adoption of digital technology has been so fast that it has posed new threats to privacy of information in the world. Governments and individuals are now appreciating the idea that data privacy needs to be defined through clear rules in the law and enforced. The two countries, Saudi Arabia and the United States have devised alternative solutions to these problems as they have different legal traditions and policy priorities. In 2021, Saudi Arabia passed the Personal Data Protection Law that took effect in September 2024, establishing the first extensive data protection legislation in the Kingdom.¹ The United States, in its turn, still depends on a sectoral approach and has state-level legislations, such as the California Consumer Privacy Act and the number of federal laws that regulate particular industries.² This paper compares the position of the two countries regarding data privacy, access to information by the government, and the rights of the individuals within the digital context. It has been analyzed that Saudi Arabia has replicated a more integrated regulatory framework and model induced by the EU General Data Protection Regulation, but the United States has a more piecemeal system that offers different rates of protection based on the industry and the jurisdiction. It is significant to understand these differences so that businesses that operate across the borders, as well as individuals who want to ensure that their personal information is safe, can appreciate such differences.

SAUDI ARABIA'S PERSONAL DATA PROTECTION LAW

The Saudi Personal Data Protection Law is an important step in the legal system of the Kingdom in ensuring the protection of personal data. The PDPL was first introduced in 2021 and revised in 2023, and has a further grace period of 2024. Being the first integrated law that encompasses the issue of protecting information in Saudi Arabia, the PDPL began to operate since September 14, 2024.³ The law contains clauses concerning the rights of data subjects, informed consent, data access, limitations in data processing, anonymization, legitimate interest and data processors as well as the disclosure requirements. The Saudi Data and Artificial Intelligence Authority is the regulatory agency that has the mandate to implement and enforce PDPL. The area of law application is considerably extensive, which also includes Saudi Arabian companies and citizens as well as any other entity in other countries that handles the personal data of individuals residing in the Kingdom. This extraterritoriality implies that any

¹ Royal Decree M/19 of 9/2/1443H (16 September 2021) approving Resolution No. 98 dated 7/2/1443H (14 September 2021) (Saudi Arabia).

² Reema Bakheet Alzahrani, *An Overview of AI Data Protection in the Context of Saudi Arabia*, 3 *Int'l J. Sci. Rsch.* 206 (Mar. 2024), <https://doi.org/10.59992/IJSR.2024.v3n3p8>.

³ *Id.*

organization that handles the data of individuals in Saudi Arabia should be in line with the PDPL, irrespective of the location of the organization handling the data. The PDPL addresses such principles as purpose limitation, data minimization, controller obligations, informed consent, data processing restriction, data subject rights, and penalties. Lack of adherence to the law may lead to warnings, fines, potential imprisonment, recovery of claims of compensation and seizure of illegal content or money.

INFLUENCE OF THE GDPR ON SAUDI ARABIA

One of the primary forces that have shaped the rules of the personal data transfer provided in the PDPL is the General Data Protection Regulation that the Saudi Data and Artificial Intelligence Authority has used as the basis to develop its rules. The Saudi law has many similarities with the GDPR, such as similar language and concepts about the data protection principles.⁴ Nevertheless, there are also significant points of deviation of the European model in the PDPL. The revised version of the PDPL incorporated the notion of adequacy, whereby transfer of personal data to a destination in a country where there are suitable safeguards over personal information and individual rights is possible.⁵ The legislation also provided some justification of transfer of personal data beyond the Kingdom, especially when this transfer is undertaken to perform a duty of a data subject, just as contractual necessity under the GDPR. The PDPL stipulates that when the personal information is being handled, the best law regime, be it a judicial decision, other legal regime or an international treaty the Saudi Arabia is a signatory to shall take effect.⁶ Regardless of these similarities, critics observe that the PDPL does not have some transfer mechanisms under the GDPR, including standard contractual clauses and binding corporate rules, which are generally used in international privacy laws.⁷ Lack of such mechanisms poses a problem to organizations that intend to move data across the borders.

UNITED STATES SECTORAL APPROACH TO PRIVACY

In contrast to the broad-based framework implemented in Saudi Arabia, the United States has adopted the sectoral approach to data privacy which oversees industries and information of particular types and concerns with the help of various laws. A number of laws at the federal level offer protection of specific types of data. The Health Insurance Portability and

⁴ Brian Meenagh & Lucy Tucker, Saudi Arabia Issues Amended Data Protection Law for Consultation, 40 Computer & Internet Law. 8, 8 (Mar. 2023).

⁵ Id.

⁶ Mustafa Alhababi, Cross-Border Data Transfer, 13 Global J. Comp. L. 178, 192 (2024).

⁷ Global Data Alliance, Comments on the Draft Amendment to the Personal Data Protection Law at 3 (Sept. 2022).

Accountability Act safeguards medical data that are stored by healthcare facilities and health plans.⁸ The Gramm-Leach-Bliley Act governs the way financial institutions deal with information about their customers.⁹ The Electronic Communications Privacy Act includes interception of both electronic communications and stored communications.¹⁰ Computer Fraud and Abuse Act criminalizes the activities of hacking and unauthorized access to computer systems.¹¹ The Fair Credit Reporting Act regulates the collection and use of credit information by the consumer reporting agencies.¹² The Federal Trade Commission Act provides the FTC with powers to initiate enforcement proceeding against unfair or deceptive conduct, and such violations of privacy.¹³ Such sectoral approach implies that privacy protection is considerably different in relation to the type of data and industry. No uniform federal law exists and cuts across all sectors. It is said by some commentators that this disjointed system causes confusion and gives way to gaps in protection while others say that sector specific rules enable more specific regulation that takes into consideration the unique features of the various industries.

CALIFORNIA CONSUMER PRIVACY ACT

California is leading in the state of the US in enacting detailed privacy laws. California Consumer Privacy Act, which was signed in 2018 and revised by the California Privacy Rights Act, gives the California residents some important rights concerning their personal data.¹⁴ The CCPA covers companies conducting trade in California which fulfill some of the requirements regarding their turnover or data processing amounts. The law grants consumers a right to know what personal information is gathered about them, deletion of personal information, the right to refuse sale of personal information, and non-discrimination in the exercise of their privacy rights. The consumer definition of the CCPA is wide, where any natural person is a resident of California, presumably also covering employees that are residents of California. The CCPA obliges businesses to adopt sensible security policies and protocols in order to safeguard personal data. Such a breach of the law may attract civil fines by the California Attorney General or the California Privacy Protection Agency. Interestingly, the California Civil Code 1798.150 gives a direct right to action in case of any type of breach to personal information that may be subjected to and causes damage to a consumer: either a statutory damages of 100-750

⁸ 42 U.S.C. § 1320d-6 (1996).

⁹ 15 U.S.C. §§ 6801-6827 (1999).

¹⁰ 18 U.S.C. § 2510 et seq. (1986).

¹¹ 18 U.S.C. § 1030 (1986).

¹² 15 U.S.C. §§ 1681 et seq. (1970).

¹³ 15 U.S.C. §§ 41-58 (1914).

¹⁴ Cal. Civ. Code § 1798.100 et seq. (2018).

USD per consumer per incident or actual damages, whichever is greater.¹⁵ This is an important enforcement mechanism and this right of action of the CCPA is unique compared to most other privacy laws.

DATA SUBJECT RIGHTS IN SAUDI ARABIA

Under the PDPL, the user of the personal data is entitled to a number of rights over the information. The subjects of data must be informed about how their information is used and why it is needed legally. They are entitled to get their personal information at controllers. They can demand the correction or modification of their data in case it is not accurate. They can also demand their information to be deleted in case it is not needed anymore due to the purpose it was gathered.¹⁶ PDPL compliance can be the issue raised by data subjects to the relevant regulatory body. Patients have a right to withdraw their consent. But the PDPL clarifies that the data subject is not obligated to give consent to all the data processing. Processing without consent may be made in case it would clearly benefit the subject of the processing and contacting the subject appears to be impractical or impossible, or the processing is necessary by the law or previous agreement to which the subject is a party, and the processing is necessary to ensure safety or in the course of a judicial proceeding. The controller may temporarily restrict access to personal information in the case where the restriction is necessary to protect the rights, freedoms or interests of the data subject or another individual. A state entity controller can limit the right of access because of its security-related reasons or the need to adhere to a specific framework or judicial reasons. After the processing is complete, the controller should by deleting the personal information ensure that after the original purpose is accomplished.

DATA SUBJECT RIGHTS UNDER THE CCPA

The California Consumer Privacy Act gives the Californians some significant rights as far as their personal information is concerned. Consumers are entitled to demand that business reveals the personal information they gather, utilize, reveal, and market. There are no charges on providing this information, and the businesses are obliged to do it twice a year. Consumers would be entitled to insist that any information that the business has gathered about them should be deleted under some exceptions. Consumers should be allowed to make a choice on whether to sell their personal information or not, and the businesses should have a clear link on their homepage which is called Do Not Sell My Personal Information. Consumers must be able to

¹⁵ Cal. Civ. Code § 1798.150 (2018).

¹⁶ Mustafa Alhababi, Cross-Border Data Transfer, 13 Global J. Comp. L. 178, 192 (2024).

exercise the right to non-discrimination, which would imply that business cannot deny goods or services, offer varied prices, or offer a different level of quality or quality of goods or services to exercise their CCPA rights. The legislation provides that any clause of a contract which tends to renounce or restrict consumer rights shall be invalid and inadmissible.¹⁷ In contrast to most other privacy laws, the CCPA offers a narrow form of privacy breach private right of action. When a business does not follow and engage in reasonable security procedures and practices and this fact leads to a breach of unencrypted or unredacted personal information, consumers are able to sue the business in a civil case to receive damages.¹⁸ This enforcement tool provides the consumers with direct authority to hold the businesses liable in terms of security breaches.

COMPARATIVE ANALYSIS OF INDIVIDUAL RIGHTS

The United States and Saudi Arabia understand the need to provide individuals with rights in relation to their personal information, but they also differ in what concerns enforcement in several ways. The PDPL offers a full range of rights that can be found in the GDPR, such as the right to access, rectify, delete, and be notified. Nonetheless, the PDPL does not grant individuals any right of action in seeking to recover damages at the hands of data controllers who infringe their rights. Rather, the enforcement is administrative in nature, where the Saudi Data and Artificial Intelligence Authority serves in the imposition of sanctions, and in resolving disputes.¹⁹ By comparison, the CCPA grants residents of California a narrow private cause of action in specific data breaches, enabling them to pursue statutory damages without demonstrating any actual damage. This disparity replicates larger differences between the legal systems. The administrative enforcement model used by Saudi Arabia places the government regulators with the main responsibility of safeguarding individual rights. In California, especially in the US system, the government enforcement is supported by the private litigating by individuals, which is very potent as a deterrent. It has been proposed that private rights of action may lead to better accountability through the ability of the affected persons to directly oppose violations. Nevertheless, they generate litigation risk to business. Lack of a right of action in the PDPL may lead to a decrease in compliance costs but may undermine protection in case of inadequacy in regulatory enforcement.

GOVERNMENT ACCESS TO DATA IN SAUDI ARABIA

¹⁷ Cal. Civ. Code § 1798.192 (2018).

¹⁸ Cal. Civ. Code § 1798.150 (2018).

¹⁹ Hanan Ali Alnasser, *The Concept of Negligence in Data Breach: A Comparative Doctrinal Analysis of the EU, California, and Saudi Arabia*, 22 *Veredas do Direito*, No. 3, at 13 (2025).

The PDPL contains a number of provisions that enable companies to reveal personal information under the circumstances. The legislation acknowledges that the processing without consent is allowed when the controller is a government agency and the procedure is necessary because of safety or judicial reasons. It may impose limitations on the disclosure of personally identifiable information in case such disclosure would jeopardize national security, tarnish the reputation of the Kingdom or cause a detriment to diplomatic relationships among Saudi Arabia with other nations.²⁰ A state entity controller can limit individual rights to access data due to reasons of security or to conform to a separate framework or due to judicial purpose. The PDPL also touches on the issue of cross-border data transfers and in this case, controllers are not allowed to transfer personal data beyond Saudi Arabia unless there are special conditions.²¹ Transfer may be made where necessary in order to fulfill an agreement with the Kingdom, to advance the interests of Saudi or some other reason provided under the executive regulations. Such transfers need a license by the Saudi Data and Artificial Intelligence Authority. Although these provisions are valid in terms of national security and safety of people, it also poses a possibility of government spying. The aspect of procedural protection which is not so elaborated in the PDPL concerning the access of the government creates concern with respect to security versus privacy. The PDPL does not offer a lot of information regarding how and when government bodies will be able to access personal data, as compared to certain other jurisdictions.

GOVERNMENT ACCESS TO DATA IN THE UNITED STATES

The American legal system is a complicated set of rules that regulates the industry of access by the government to individual information. The Fourth Amendment of the Constitution safeguards against unreasonable searches and seizures by making government officials do so only upon retaining warrants, but on probable cause, before carrying out most forms of searches.²² The extent of Fourth Amendment coverage has however been on a subject of constant controversy especially when it comes to digital information. In *Carpenter v. United States*, the Supreme Court held that the government must obtain a warrant before accessing historical cell site location information from wireless carriers.²³ The Court acknowledged that citizens have a justifiable right of privacy of their physical activities and physical location

²⁰ Royal Decree M/19, art. 29 (Saudi Arabia).

²¹ Mustafa Alhababi, Cross-Border Data Transfer, 13 *Global J. Comp. L.* 178, 192 (2024).

²² *Griswold v. Connecticut*, 381 U.S. 479 (1965).

²³ *Carpenter v. United States*, 138 S. Ct. 2206 (2018).

information.²⁴ The USA PATRIOT Act, which was enacted in the wake of the September 11 attacks, broadened the capabilities of the government to spy on its people, enabling them to read cellular information, such as contacts, messaging, and web history.²⁵ Through the collaboration of the mobile providers, the government is able to intercept all the correspondence through telephone that is sent across state boundaries and remote communication. The Electronic Communications Privacy Act regulates government interception of electronic communications and stored data even though most privacy activists claim that the legislation, enacted in 1986, is out of date and does not offer adequate protection to contemporary digital communications. The Foreign Intelligence Surveillance Act creates government surveillance procedures to use foreign intelligence information, and to do so, it has a section of 702 whereby it permits warrantless surveillance of non-US individuals outside the United States.²⁶

COMPARATIVE ANALYSIS OF GOVERNMENT ACCESS

The United States and Saudi Arabia believe that governments ought to have access to the personal information of the individuals in specific situations, especially in the context of the national security and law enforcement. Nevertheless, they act in response to the problem using various legal provisions and protections. The United States system has constitutional provisions in the Fourth Amendment that mandates warrants in most forms of governmental searches. Most recent cases such as *Carpenters* have reinforced the privacy protection in the virtual realm by expanding the warrant provisions to some forms of location data. There are also certain statutory limitations on government surveillance in the US system although this depends on the context. The Saudi PDPL authorizes the government access when cases are related to the national security, public safety, and judicial procedures, yet it is less specific regarding the safeguards to the process. The legislation fails to define the scenarios under which warrants or any other kinds of judicial control must be provided prior to the government agencies gaining access to the personal information. This indicates more general variations in legal tradition and the legal framework between the two nations. The conflict between privacy and security is present in both jurisdictions but they solve it in dissimilar ways. The US legal system is more dependent on the constitutional protections and judicial checks whereas the Saudi system is more focused on the administrative discretion. No system is ideal in regard to

²⁴ Id. at 2217.

²⁵ Pub. L. No. 107-56, 115 Stat. 272 (2001).

²⁶ 50 U.S.C. § 1881a (2008).

the privacies of individuals and both have continued in their struggle to keep up with emerging levels of surveillance.

CROSS-BORDER DATA TRANSFERS

The cross-border data transfers is one of the most critical spheres where Saudi Arabia and the United States differ considerably in their strategies. The Saudi PDPL is restrictive in terms of international data transfers, which is based on the GDPR model. Data controllers are also not allowed to send personal data outside Saudi Arabia except in certain circumstances.²⁷ The law mandates that data transfer may only be made to countries that are found to give a sufficient protection to personal data like the process of adequacy determination under the GDPR. The Saudi Data and Artificial Intelligence Authority has published recommendations on cross-border transfers, and is creating adequacy decisions concerning different countries. Nonetheless, in contrast to the GDPR, the original version of the PDPL did not include certain standard transfer mechanisms that can be used to support international data flows, including standard contractual terms and binding corporate rules.²⁸ The revised draft added some more grounds of transfers but offers still less options compared with the European one. This restrictive method has cast some fear to businesses regarding the real problems of compliance. The Global Data Alliance has observed that in case the PDPL is construed to bar data transfer to any other country that does not have the same data protection measures, it would potentially have a chilling effect on Saudi Arabia in its relationship with the rest of the world via information and communications technology networks.²⁹

US APPROACH TO INTERNATIONAL DATA TRANSFERS

The United States has an entirely different attitude toward cross-border data transfers, and does not have a transfer regime similar to the GDPR or the Saudi PDPL. Rather, the US upholds the international data flows through a number of sectoral laws and contractual mechanisms. No general federal legislation exists that provides adequacy determinations or necessitates certain protection on data received outside the United States. The CCPA lacks a direct transfer regime, but it mandates businesses to take reasonable security measures of personal information in any location. There are certain federal laws, which limit the transfer of certain data. As an

²⁷ Mustafa Alhababi, Cross-Border Data Transfer, 13 Global J. Comp. L. 178, 192 (2024).

²⁸ Global Data Alliance, Comments on the Draft Amendment to the Personal Data Protection Law at 3 (Sept. 2022).

²⁹ Global Data Alliance, Comments on the Draft Amendment to the Personal Data Protection Law at 3-4 (Sept. 2022).

illustration, the Health Insurance Portability and Accountability Act also obligates covered entities to make sure that their business partners, even those in other countries, should secure health information in a proper manner. These requirements are however geared towards contractual requirements, but not destination based restrictions. The lack of an extensive US transfer system articulates the sectoral approach to the regulation of privacy. This brings about both benefits and demerits. On the one hand, it gives a leeway on which businesses can create transfer mechanisms which are befitting their unique situations. Conversely, it brings in confusion and might offer less reliable security to people. Absence of single transfer regime also makes international data sharing negotiations difficult.

BREACH NOTIFICATION REQUIREMENTS

The two jurisdictions understand the significance of prompt notification in case of security breach involving personal data. The Saudi PDPL mandates data controllers to inform the Saudi Data and Artificial Intelligence Authority of a breach within 72 hours of its identification.³⁰ This is a timeline that reflects the need in the GDPR. The controllers should also inform the affected data subjects without unnecessary delay in case the breach is a high risk to the rights and freedoms of the data subjects. The law offers a guideline by enacting laws that specify what is required in the notices of breaches and what action has to be taken to address the damages by the controllers. The consequences of not giving the notification on time may include administrative penalties and sanctions by the regulatory authority. In the United States, breach notification laws depend upon jurisdiction. One of the earliest laws in breach notification was Californian Civil Code section 1798.82, which (as it was originally written) obliged any person or business with operations in California that maintains or licenses any computerized data containing personal information to notify of any security breach to California residents.³¹ Every state in the United States currently possesses some kind of breach notification legislation, albeit with various provisions in terms of when and what is required to be provided as well as the notification threshold. Breach notification laws are also sector specific at the federal level. Health Insurance Portability and accountability act demands covered entities to disclose to the affected individuals, the department of health and human services and in some instances the media in event that there is an attack on the protected health information.³²

³⁰ Hanan Ali Alnasser, *The Concept of Negligence in Data Breach: A Comparative Doctrinal Analysis of the EU, California, and Saudi Arabia*, 22 *Veredas do Direito*, No. 3, at 13 (2025).

³¹ Cal. Civ. Code § 1798.82 (2003).

³² 45 C.F.R. § 164.408 (2013).

ENFORCEMENT AND PENALTIES

The regulations and sanctions of the laws of infraction are also very different in Saudi Arabia and the United States. Within the framework of the PDPL, the Saudi Data and Artificial Intelligence Authority is the main enforcement organization that has the authority to trace the violations and apply penalties and orders to make people comply.³³ The law provides several punishments such as warnings, fines, potential imprisonment and compensation claims, seizure of infringing material or money. The authority is also empowered to pass binding rulings of disputes that are liable to legal review. This type of centralized enforcement focuses regulation on one governmental body that oversees the observance of regulatory measures in all industries. In the United States, regulation is more scattered, as the regulation of privacy is in a sectoral fashion. The consumer protection mandate of the Federal Trade Commission gives it wide powers to take enforcement measures against unfair or deceptive practices including violations of privacy. Attorneys general in states have a chance to implement state privacy legislation and initiate action under federal statutes. Regulators that are specific to the sector, e.g., HIPAA violations by the Department of Health and Human Services, are empowered to act in their area. By the California Privacy Rights Act, the California Privacy Protection Agency was formed, which is given the sole power to enforce the CCPA. The CCPA, in contrast to the system in Saudi Arabia, also offers personal implementation of the law by the right of action, which is quite limited and operates to recover damages in case of data breaches, as it gives the possibility to directly file a law suit against a business. The CCPA provides the greatest civil penalty of 2,500 per violation or 7,500 in case of intentional violations.³⁴

CONSENT REQUIREMENTS

Consent is an essential premise of legal data processing in both legal systems, but they vary in the key aspects of the necessity of consent and the manner of its collection. The Saudi PDPL lays much emphasis on consent as the major law that requires the use of personal data. Most cases demand that controllers seek informed consent of data subjects prior to processing their information as stipulated in the law. Nevertheless, the PDPL acknowledges a number of exceptions to processing without the consent, such as processing would obviously be in the beneficial interest of the data subject and contacting the data subject would be unfeasible, processing is mandated by law or an earlier agreement, and processing is necessary due to

³³ Reema Bakheet Alzahrani, *An Overview of AI Data Protection in the Context of Saudi Arabia*, 3 Int'l J. Sci. Rsch. 206 (Mar. 2024), <https://doi.org/10.59992/IJSR.2024.v3n3p8>.

³⁴ Cal. Civ. Code § 1798.155 (2018).

safety or judicial considerations by a governmental agency. The updated version of the PDPL provided an introduction of a legitimate interests as an extra-legal ground of processing non-sensitive personal data in a similar way as under the GDPR.³⁵ This enables the data controllers to weigh their interests with the data subject rights. The application of the principle of consent in the CCPA works slightly differently. The law typically permits businesses to gather and utilize personal information without express approval, but it demands the notifying of the businesses on its data utilization methods and provides the consumer the option of not consenting to the sale of his or her personal information. In the case of consumers who are less than 16 years, the law mandates the consent of the consumer before their personal data is sold. The CCPA is more focused on transparency and choice by consumers, instead of having prior approval to all processing functions.

SENSITIVE DATA PROTECTION

The two jurisdictions acknowledge that there are some groups of personal information that should be accorded extra protection because of their sensitivity. The GDPR provides special protection to such categories of data as racial or ethnic origin, political views, religion, trade unions, genetic information, biometric data, health information, and data concerning sex life, or sexual orientation.³⁶ Saudi PDPL is conceptually broad in determining personal data and regulates sensitive groups by accompanied by regulations and guidance by Saudi Data and Artificial Intelligence Authority, yet the law does not specify more precisely what is sensitive data and what other safeguards are applicable.³⁷ This leaves certain confusion on the compliance requirements to organizations which may have potentially sensitive information. The standards to sensitive information vary in the U.S. according to various laws. The version of CCPA that has been amended with the California Privacy Rights Act defines sensitive personal information as the social security number, the driver/license number, the financial accounts information, the accurate geolocation information, the racial or ethnic background, the religious or philosophical conviction, the union membership, genetic data, biometrical data, health data, and the information related to the sexual orientation or the sex life. The law provides the consumers with the right to restrict the usage and transmission of their sensitive personal information. Federal regulations such as the HIPAA offer all-inclusive protection to

³⁵ Brian Meenagh & Lucy Tucker, Saudi Arabia Issues Amended Data Protection Law for Consultation, 40 Computer & Internet Law. 8, 8 (Mar. 2023).

³⁶ Regulation (EU) 2016/679, art. 35 (General Data Protection Regulation).

³⁷ Hanan Ali Alnasser, The Concept of Negligence in Data Breach: A Comparative Doctrinal Analysis of the EU, California, and Saudi Arabia, 22 Veredas do Direito, No. 3, at 13 (2025).

health information, whereas other forms of sensitive data might be subjected to a restricted level of protection. The sectoral approach implies that the degree of protection of delicate information is dissimilar based on the legal framework in terms of the specific type of information and industry.

ACCOUNTABILITY AND SECURITY MEASURES

The two legal frameworks oblige data controllers to take reasonable security precaution in safeguarding personal data, but the two systems differ in the manner through which they establish and mandate such requirements. The Saudi PDPL also dictates that the controllers will apply organizational, administrative, and technical safeguards to ensure that personal data is not subjected to unauthorized access, disclosure, modification, or destruction. The law reiterates the need of the controller to ensure that data security and confidentiality are enforced during the processing lifecycle. Introducing the regulations and guidelines suggested by the Saudi Data and Artificial Intelligence Authority give more information regarding anticipated security practices. The PDPL, however, does not stipulate that data protection impact assessment be done on high-risk processing activities like the GDPR would have nor stipulated that high-risk processing activities should have data protection impact assessment as mandatory as required by Article 35.³⁸ The CCPA covers reasonable security procedures and practices that should be established and observed by business depending on the type of information they relate to. Otherwise, the failure of the business to apply reasonable security can make it liable to the provisions of the private right of action in case of breach. In California law, sector specific security requirements are also provided, including those contained within California Civil Code Section 1798.81.5 that mandates businesses implement reasonable security measures of personal information. The impact of the GDPR can be seen in the two systems as each of them has taken the risk-based approach to security and in which organizations must evaluate the risks and take the measures that are relevant to those risks. Nevertheless, the concrete requirements and enforcement mechanisms vary, and detailed systems are offered by the GDPR and PDPL in comparison with the CCPA.

CHALLENGES AND FUTURE DIRECTIONS

Saudi Arabia and United States are currently struggling to introduce changes in their data protection systems to the fast changing technology as well as the shifting societal demands. The

³⁸ Regulation (EU) 2016/679, art. 35 (General Data Protection Regulation).

PDPL of Saudi Arabia is a great step toward the creation of the full-fledged data protection, yet a number of aspects should be improved. The legislation does not provide similar data portability rights as those in the GDPR which would enable people to switch the service provider with their data without much difficulty.³⁹ The PDPL does not provide the means of someone objecting to processing or contesting automated decision-making, which is gaining significance as the use of artificial intelligence systems grows. Lack of a personal right of remedy implies that people have no other option but complete administrative application that might not be adequate to safeguard their rights to the fullest. The Saudi regulatory environment would also use additional autonomy of the oversight body and additional specifications of compliance requirements in various industries. The biggest issue in the United States is the absence of the federal law on privacy. The sectoral approach is confusing, expensive to compliance to businesses with operations in multiple jurisdictions, and fails to protect people unequally because of the location where they live and the nature of the data in question. Several attempts to pass federal privacy acts have failed in Congress because of conflicting views on some of its major provisions such as whether to override state laws, as well as whether to provide a private right of action.

CONCLUSION

This comparative analysis demonstrates the basic differences between the ways Saudi Arabia and the United States address the problem of data protection due to their different legal traditions, governmental frameworks, and priorities of their policies. Adopting an integrated and holistic model based in large part on the European GDPR, Saudi Arabia has developed coherent and uniform rules that govern all industries and introduce a centralized regulatory body to oversee their execution. This method offers uniformity and solidity but puts too much power in the hands of government regulators and offers fewer ways of individuals enforcing their rights directly. The United States is still dependent on a fragmented, sectoral strategy that depends on industry and jurisdiction. Although this system has a certain degree of flexibility and can be customized to a specific degree, it makes it confusing, complicates the compliance process, and causes gaps in protection. The CCPA is a significant move as it grants full rights to all California residents, although it is not yet the same throughout the nation since there is no federal law. The two systems have difficulties when it comes to balancing privacy protection and other essential interests, such as national security, safety, and economic growth. Both have

³⁹ Hanan Ali Alnasser, *The Concept of Negligence in Data Breach: A Comparative Doctrinal Analysis of the EU, California, and Saudi Arabia*, 22 *Veredas do Direito*, No. 3, at 13 (2025).

to adjust to the new technologies such as artificial intelligence and make sure that their frameworks can withstand the changes in data processing practices. In the case of businesses with international operations, such differences must be understood in order to comply. To individuals, these structures predetermine the levels of control they may have over their personal data and the recourse they may take in case their rights are infringed. With the ongoing digital technology revolution of society, the two nations will have to perfect their strategies to make sure that data protection catches up with this new technology without infringement of basic rights.

BIBLIOGRAPHY

Cases

Carpenter v. United States, 138 S. Ct. 2206 (2018).

Griswold v. Connecticut, 381 U.S. 479 (1965).

Statutes

Royal Decree M/19 of 9/2/1443H (16 September 2021) approving Resolution No. 98 dated 7/2/1443H (14 September 2021) (Saudi Arabia).

California Consumer Privacy Act of 2018, Cal. Civ. Code § 1798.100 et seq.

California Civil Code § 1798.82 (2003).

California Civil Code § 1798.150 (2018).

Computer Fraud and Abuse Act, 18 U.S.C. § 1030 (1986).

Electronic Communications Privacy Act of 1986, 18 U.S.C. § 2510 et seq.

Fair Credit Reporting Act, 15 U.S.C. § 1681 et seq. (1970).

Federal Trade Commission Act, 15 U.S.C. §§ 41-58 (1914).

Foreign Intelligence Surveillance Act, 50 U.S.C. § 1881a (2008).

Gramm-Leach-Bliley Act, 15 U.S.C. §§ 6801-6827 (1999).

Health Insurance Portability and Accountability Act of 1996, 42 U.S.C. § 1320d-6.

USA PATRIOT Act of 2001, Pub. L. No. 107-56, 115 Stat. 272.

Regulations

HIPAA Breach Notification Rule, 45 C.F.R. § 164.408 (2013).

Regulation (EU) 2016/679 (General Data Protection Regulation).

Secondary Sources

Ali Polat, Effects of GDPR on the Financial Services Sector in the Kingdom of Saudi Arabia, 4 J. Data Prot. & Privacy 1-10 (2021).

Global Data Alliance, Comments on the Draft Amendment to the Personal Data Protection Law (Sept. 2022).

Hanan Ali Alnasser, The Concept of Negligence in Data Breach: A Comparative Doctrinal Analysis of the EU, California, and Saudi Arabia, 22 *Veredas do Direito*, No. 3, e223404 (2025).

International Journal for Scientific Research, Personal Data Protection Law in Saudi Arabia, Vol. 3, No. 3, at 206 (Mar. 2024), <https://doi.org/10.59992/IJSR.2024.v3n3p8>.

Meenagh, Brian & Lucy Tucker, Saudi Arabia Issues Amended Data Protection Law for Consultation, 40 *Computer & Internet Law*. 8 (Mar. 2023).

Mustafa Alhababi, Cross-Border Data Transfer, 13 *Global J. Comp. L.* 178 (2024).